

Autonomous Threat Hunter

Insider attacks surfaced from raw enterprise logs — without a black box a SOC team can't question.

CodeManiacs

Team Leader Vaidehi Turkar
Members Vaidehi Turkar · Shashwat

Live now

threat-hunter-dashboard.onrender.com
threat-hunter-api.onrender.com
github.com/Vaidehi2502/autonomous-threat-hunter

Insiders don't break in. They log in.

- **No malware, no intrusion.** An insider already holds valid credentials. Perimeter tools, antivirus and firewalls see nothing wrong.
- **The signal is purely behavioural.** The only evidence is a change in how someone acts — hours kept, machines used, data moved.
- **The volume defeats humans.** 4,000 employees over 18 months is 1,393,138 user-days. Nobody reads that.
- **And the usual fix backfires.** Drop in a black-box anomaly model and a SOC team gets alerts it cannot explain, cannot triage, and stops trusting. That is the false-positive trap this problem statement calls out.

Our answer, in one line

Score every user-day against that person's own history — and make every flag explain itself.

Three decisions that make it trustworthy

01

Per-user baselines, not a population average

A stockroom clerk and a physicist have different normals. Against a company-wide mean, one drowns real anomalies and the other hides them.

Every user is compared only to themselves.

02

ML is a second opinion, never the verdict

An Isolation Forest catches multivariate patterns rules miss — but it only adds weight, never decides alone.

A test asserts the model on its own can never reach High or Critical.

03

Explains itself, two different ways

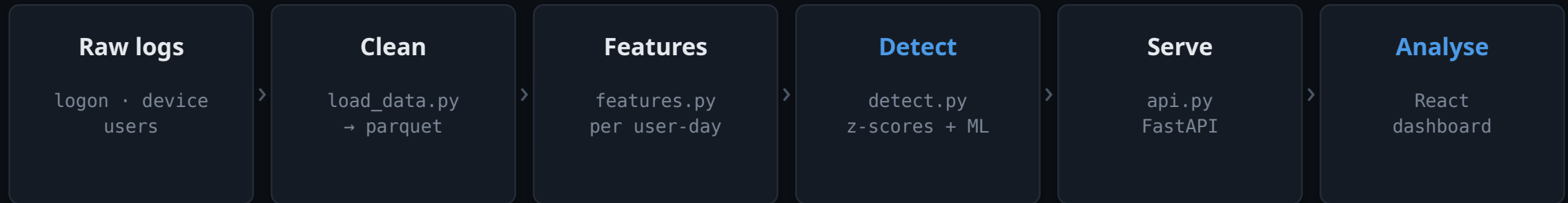
Every reason names the exact counterfactual threshold. A separate 14-day trend signal also catches sustained escalation no single day's z-score can see — without touching a single severity figure.

Two failure modes covered, not one — see Slide 6 for the count.

Every flagged day carries a reason an analyst can act on or dismiss:

"off hours usb count unusually high (z=9.5) — would not flag below 1.1 (actual: 4)"

Architecture & scoring engine



Five features, weighted

off-hours logons · weight 3
off-hours USB · weight 3
USB connects · weight 2
distinct PCs · weight 2
logon count · weight 1

Severity from the total

Critical score ≥ 8
High score ≥ 5
Medium score ≥ 2
Low score > 0

Rule weights past $z = 2.5$, plus 2 if the model agrees.

RESULTS

What it found

1,393,138

user-days analysed

4,000

employees, 18 months

50,520

flagged (3.6%)

377

Critical days

SEVERITY BREAKDOWN



Case study — EYD2871

ProductionLineWorker, Assembly

52 of 358 days flagged — 9 Critical, 21 High, 22 Medium — recurring across 13 months, not one bad week.

Same signature every time: off-hours logons, off-hours USB, and far more distinct PCs than a fixed workstation role should need.

Built to be run, not just demoed

80

automated tests, CI on every push

330 MB

memory, down from 870 MB

< 1 s

response over 1.39M rows

Live

deployed, not a localhost demo

— **Tests encode the argument.** One asserts the same raw value is anomalous for a quiet user and normal for a busy one. Another asserts the ML model alone can never reach a High verdict, and a third proves a sustained trend is caught even when no single day's z-score is.

— **Measured, not guessed.** Memory was profiled in a limited container — 256 MB is killed, 384 MB runs — which is why it fits a free instance.

— **Secured deliberately.** Per-client rate limiting, named per-analyst API keys, hardened response headers, explicit CORS allowlist. Every read of an employee's timeline is audit-logged and attributed to the analyst who looked it up.

Try it threat-hunter-dashboard.onrender.com

API threat-hunter-api.onrender.com/docs

Where this goes

Scales without redesign

- Read-only and stateless — add instances, no coordination needed.
- Detection runs offline and parallel; serving is a precomputed table.
- Per-user baselines mean no retuning when new roles or teams appear.
- Any log with a timestamp and an actor fits the same pipeline.

Honest next steps

- 47,600 Medium flags is a real triage load — tune thresholds, or treat Medium as a watchlist rather than a page.
- Only logon and device data so far. Email, file and web logs add the most direct exfiltration signals.
- Keys today are shared secrets in an env var — real rollout needs self-service issuance, rotation, and per-analyst data scoping.

Every alert explains itself.

That is what makes it usable by a real security team, instead of one more model they learn to ignore.